QAYRAWAN INFORMATION SYSTEMS

AI Usage Policy and Procedure

ECC Compliance Program · Govern phase

Document ID	QIS-POL-002
Version	0.1 (Draft)
Date	7 November 2026
Classification	Internal
Prepared by	Naif Alsalem, GRC Lead

Language. This document is issued in Arabic and English. In case of conflict, the Arabic text prevails.

Fictional case study. Qayrawan Information Systems (QIS), its people and its clients are invented for a professional portfolio. Any resemblance to a real organization is unintended. The regulators and frameworks named are real.

Document control

Role	Job title	Name	Status
Owner	GRC Lead	Naif Alsalem	Complete
Reviewer	Chief Technology Officer	Reem Al-Otaibi	Pending
Endorsed by	Cybersecurity Steering Committee	—	Pending
Approver	Chief Executive Officer	Faisal Al-Harbi	Pending

Version history

Version	Date	Author	Change
0.1	7 Nov 2026	Naif Alsalem	First draft for review, translated from the Arabic lead text

Review cycle: Every six months during the first year, given how fast AI technology is moving, then annually, and when the final version of the National Cybersecurity Authority's AI guidelines is issued.

Indicator colour key

Colour	Status	Meaning and required action
Green	**On target**	Within the acceptable limit. Routine monitoring continues.
Amber	**Needs attention**	Approaching the acceptable limit. Requires follow-up and correction within the set period.
Red	**At risk or non-compliant**	Past the critical threshold. Requires immediate escalation to senior management and an urgent treatment plan.

1. Definitions

Term	Definition
AI tool	Any service or software that generates text, code, images or decisions using machine learning models, such as generative assistants and coding assistants.
Approved tool	A tool listed in the register of approved AI tools after assessment under section 6.
Prompts	The text and files a user enters into an AI tool.
Client data	Any data, code, documents or configuration belonging to Clients A to F, whatever its classification.
Human oversight	Review and approval of AI output by a competent person before it is used.

Term	Definition
Prompt injection	An attempt to steer an AI model with crafted input so it bypasses its instructions or discloses data.

2. Purpose

This policy lets Qayrawan Information Systems staff use AI tools to work more productively, while protecting government clients' data and systems and complying with national regulations, guidelines and AI ethics principles.

3. Scope

- All staff and contractors who use AI tools in QIS work or client work.
- AI features that QIS builds or integrates into the systems it develops or hosts for clients.
- AI tool vendors QIS works with.

4. Principles

Principle	What it means at QIS
Privacy and security	Client data and personal data never go into tools not approved for them, and client data is never used to train any model.
Accountability	Staff remain responsible for any output they use; decisions are never attributed to the tool.
Transparency	AI use is disclosed to the client whenever the contract requires it or the output is aimed at citizens.
Fairness	AI features are not used in decisions affecting citizens without bias testing and the client's approval.
Reliability	Outputs are treated as drafts that need checking, not as established facts.

These principles align with the AI Ethics Principles issued by the Saudi Data and Artificial Intelligence Authority (SDAIA).

5. Policy statements

5.1 Approved tools only

1. The GRC Lead keeps a register of approved AI tools, setting out for each tool the permitted uses and the highest data classification that may be entered.

2. No tool outside the register may be used for QIS or client work. A new tool must be requested through the procedure in section 6.

Key performance indicators (KPIs)

Code	Indicator	Target	Frequency
KPI-01	Share of AI tools in use at QIS that are listed in the approved register	100%	Quarterly

Key risk indicators (KRIs)

Code	Indicator	Threshold	Frequency
KRI-01	Number of unapproved AI services detected in network traffic	Green: 0 Amber: 1 to 3 Red: 4 or more	Monthly

5.2 What data may be entered

Data type	Public, unapproved tool	QIS-approved tool	Additional condition
Public data	Not allowed for QIS work	Allowed	—
QIS internal data	Not allowed	Allowed	Within the uses set in the register
Client data or code	Not allowed	Not allowed by default	Written client approval, and the tool hosted in the Kingdom
Personal, Restricted or higher data	Not allowed	Not allowed	No exception without a CEO decision and the controller's approval
Passwords, keys and secrets	Not allowed	Not allowed	No exception

Key risk indicators (KRIs)

Code	Indicator	Threshold	Frequency
KRI-02	Number of data loss prevention alerts for client data sent to AI services	Green: 0 Amber: 1 Red: 2 or more	Monthly

5.3 Use in software development

1. AI-generated code is treated as untrusted code: it must pass peer review, security scanning and dependency scanning in the build pipeline, and is not merged without them.

2. Developers check the licence of any code or library a coding assistant suggests.

3. Coding assistants are used on client repositories only if the tool is approved for that and the client agrees.

Key performance indicators (KPIs)

Code	Indicator	Target	Frequency
KPI-03	Share of merged changes that passed review and security scanning	100%	Monthly

5.4 Human oversight and accountability

1. A competent person reviews every AI output before it is used in client deliverables, official documents or decisions.

2. No automated decision affecting citizens or client staff is made without human review and the client's written approval.

5.5 AI features in client systems

1. No AI feature is added to a client system without the client's written approval and a risk and data protection impact assessment.

2. Security by design applies. Threat modelling covers prompt injection, data leakage through outputs and model misuse, drawing on the National Cybersecurity Authority's draft AI cybersecurity guidelines.

3. The feature's inputs and outputs are logged so incidents can be investigated, with personal data protected in the logs.

Key risk indicators (KRIs)

Code	Indicator	Threshold	Frequency
KRI-05	Number of AI features running in client systems without an approved risk assessment	Green: 0 Red: 1 or more	Quarterly

5.6 AI tool vendors

Each vendor is assessed before approval on: where data is processed and hosted, how long it keeps inputs, a commitment not to use them to train its models, its security controls, and the contract terms. The assessment is repeated annually.

Key performance indicators (KPIs)

Code	Indicator	Target	Frequency
KPI-06	Share of approved tools whose vendor was reassessed in the last 12 months	100%	Quarterly

5.7 Awareness

Every employee and contractor completes short training on this policy before receiving any approved tool, and annually after that.

Key performance indicators (KPIs)

Code	Indicator	Target	Frequency
KPI-07	Share of approved-tool users who completed the training	100%	Quarterly

6. Procedure for approving an AI tool

#	Step	Responsible	Output	Duration
1	Submit a request stating the tool, purpose, users and the type of data expected to be entered	Requesting employee	Request form	—
2	Line manager confirms the need	Line manager	Endorsed request	2 days
3	Risk assessment: data, hosting, retention, training on inputs, and the contract	GRC Lead	Documented risk assessment	5 working days
4	Technical review: single sign-on, multi-factor authentication, logging and integration	Chief Technology Officer	Technical recommendation	3 working days
5	Decision: approve with conditions, or reject with reasons	GRC Lead with the CTO	Documented decision	2 days
6	Add to the register, set the highest permitted classification, and inform staff	GRC Lead	Updated register	1 day
7	Annual review, or when vendor terms change; retire the tool when no longer needed	GRC Lead	Continue or retire decision	Annually

7. Roles and responsibilities

The matrix below sets out responsibilities: (R) Responsible, (A) Accountable, (C) Consulted, (I) Informed.

Activity	CEO	Steering Committee	GRC Lead	CTO	Head of Service Delivery	Staff
Approve the policy	A	C	R	C	I	I
Manage the approved tools register	I	I	A/R	C	I	I
Assess a new tool	I	I	A/R	R	C	C
Technical controls and data loss prevention	I	I	C	A/R	I	I
Review AI outputs	—	—	I	C	C	A/R
Add an AI feature to a client system	A	C	R	R	C	I
Track indicators and report	I	C	A/R	C	I	—

8. Consequences of non-compliance

Entering client data or personal data into an unapproved tool is a data incident, handled under the Incident Response Plan (QIS-IRP-001). Breaching this policy may lead to loss of access to AI tools and to disciplinary action under internal rules.

9. Review and update

The GRC Lead reviews this policy on the cycle set in document control, and keeps the approved tools register up to date.

10. References

Reference	Issuer
Draft AI cybersecurity guidelines (for public consultation, 2026)	National Cybersecurity Authority
AI Ethics Principles	SDAIA
Personal Data Protection Law	SDAIA
Essential Cybersecurity Controls (ECC-2:2024)	National Cybersecurity Authority
QIS-POL-001 Data Protection Policy	QIS
QIS-RMM-001 Risk Management Methodology	QIS

> **Note:** the National Cybersecurity Authority's AI guidelines are a draft open for public consultation. This policy will be reviewed when the final version is issued.

11. Contact

For questions or to request a tool: the GRC Lead at grc@qis.example.